



Ekibastuz Power Services JSC — Единое руководство по внутренним процессам

Питание и социально-бытовое обеспечение

Организация питания осуществляется силами подрядной организации на условиях действующего договора. Меню согласуется ежемесячно. Годовой бюджет корпоративной столовой составляет 21 468 300 тенге.

Санитарное состояние помещений столовой контролируется в соответствии с требованиями законодательства. Результаты проверок оформляются актами и хранятся у ответственного лица.

Обратная связь работников собирается ежеквартально и учитывается при формировании меню и при оценке подрядной организации.

Аренда и эксплуатация помещений

Договоры аренды ведутся централизованно; продление инициируется не позднее чем за девяносто дней до окончания срока. Показания приборов учёта снимаются ежемесячно. Совокупный годовой платёж по действующим договорам составляет 57 903 400 тенге.

Приёмка и возврат арендуемых помещений оформляются актами с фиксацией состояния и показаний приборов учёта. Замечания по состоянию помещений направляются арендодателю в письменной форме.

Работы по текущему ремонту согласуются с арендодателем в порядке, предусмотренном договором. Улучшения, неотделимые без вреда для помещения, выполняются только по письменному согласованию.

Архив и делопроизводство

Документы передаются в архив по описи в установленные сроки. Выдача документов из архива производится по заявке с регистрацией. Уничтожение документов с истёкшим сроком хранения оформляется актом.

Номенклатура дел утверждается ежегодно и определяет состав документов, сроки их хранения и порядок передачи в архив. Подразделения формируют дела в соответствии с номенклатурой.

Выдача документов во временное пользование производится на срок не более тридцати дней с отметкой в книге выдачи. Копирование архивных документов допускается с разрешения ответственного за архив.

Мероприятия и внутренние коммуникации

Планирование внутренних мероприятий осуществляется на квартал вперёд. Бюджет мероприятий утверждается руководителем и не подлежит перераспределению без согласования. Фонд признания и командных мероприятий на год составляет 3 274 850 тенге.

Информационные материалы для внутренних каналов согласуются с подразделением, отвечающим за коммуникации. Публикация сведений ограниченного распространения во внутренних каналах не допускается.

По итогам мероприятий формируется краткий отчёт с указанием фактических расходов и достигнутых целей. Отчёт представляется руководителю, утвердившему бюджет мероприятия.

Контроль и отчётность

Служба административно-хозяйственного обеспечения формирует ежеквартальный отчёт об исполнении бюджета и о состоянии инфраструктуры. Отчёт представляется руководству и хранится в общем каталоге.

Ежеквартальный отчёт включает сведения об исполнении бюджета, о состоянии инфраструктуры, о выполнении заявок подразделений и о результатах взаимодействия с подрядными организациями.

Выявленные отклонения от плановых показателей сопровождаются пояснениями и перечнем мер. Исполнение мер контролируется до их завершения и отражается в следующем отчётном периоде.

Общие положения

Настоящий стандарт устанавливает базовые требования к использованию информационных систем и оборудования. Он применяется ко всем работникам и подрядчикам, получающим доступ к корпоративным ресурсам. Несоблюдение требований может повлечь ограничение доступа.

Требования настоящего стандарта распространяются на корпоративные информационные системы независимо от места их размещения, включая системы, размещённые у внешних поставщиков услуг. Владельцы систем обеспечивают соответствие требованиям при вводе систем в эксплуатацию.

Отступления от требований допускаются в исключительных случаях по письменному согласованию со службой информационной безопасности с указанием компенсирующих мер и срока действия отступления. Реестр действующих отступлений пересматривается ежеквартально.

Учётные записи и доступ

Учётная запись создаётся на основании заявки руководителя подразделения и предоставляет минимально необходимый набор прав. Права пересматриваются при изменении должности и отзываются при увольнении. Совместное использование учётных записей не допускается.

Привилегированные учётные записи выделяются отдельно от обычных и используются только для выполнения административных задач. Их применение подлежит обязательному журналированию, а перечень владельцев пересматривается ежеквартально.

Периодическая сверка прав доступа проводится совместно владельцами систем и руководителями подразделений. Права, не подтверждённые по итогам сверки, отзываются в течение пяти рабочих дней с оформлением соответствующей записи.

Пароли и многофакторная аутентификация

Пароли должны отвечать установленным требованиям к сложности и не подлежат передаче третьим лицам. Для доступа к системам, отнесённым к критичным, применяется многофакторная аутентификация. Восстановление доступа производится службой поддержки после подтверждения личности.

Хранение паролей в открытом виде, в том числе в текстовых файлах и в записках на рабочем месте, не допускается. Для хранения служебных паролей применяется корпоративное хранилище с разграничением доступа.

Компрометация или подозрение на компрометацию пароля является основанием для его немедленной смены и уведомления службы поддержки. При компрометации привилегированной учётной записи проводится дополнительный анализ журналов за предшествующий период.

Рабочие станции и мобильные устройства

Рабочие станции комплектуются штатным программным обеспечением; установка стороннего программного обеспечения выполняется по согласованию. Мобильные устройства, используемые для работы, подлежат регистрации. Стоимость стандартного комплекта рабочего места составляет 715 480 тенге.

На рабочих станциях применяются средства защиты от вредоносного программного обеспечения с автоматическим обновлением. Отключение средств защиты пользователем не предусмотрено; временное отключение выполняется только специалистом службы поддержки.

Утрата устройства, содержащего служебную информацию, подлежит немедленному уведомлению службы поддержки для дистанционной блокировки. Расследование обстоятельств утраты проводится в общем порядке рассмотрения инцидентов.

Электронная почта и обмен сообщениями

Корпоративная почта используется для служебной переписки. Пересылка служебной информации на личные адреса не допускается. При получении подозрительного сообщения работник сообщает в службу поддержки и не открывает вложения.

Массовые рассылки внешним адресатам согласуются с подразделением, отвечающим за коммуникации. Использование корпоративного адреса для регистрации в сторонних сервисах, не связанных с работой, не допускается.

Служебная переписка, содержащая сведения ограниченного распространения, направляется с применением предусмотренных средств защиты. Пересылка таких сведений через публичные мессенджеры не допускается.

Резервное копирование

Резервные копии критичных систем создаются по установленному расписанию и хранятся в отдельном сегменте. Восстановление проверяется по плану тестирования не реже одного раза в полугодие. Результаты проверок оформляются протоколом.

Перечень систем, подлежащих резервному копированию, и глубина хранения копий определяются владельцами систем с учётом требований к непрерывности деятельности. Перечень пересматривается ежегодно.

Носители резервных копий, выводимые из обращения, подлежат гарантированному удалению данных. Доступ к хранилищу резервных копий предоставляется ограниченному кругу лиц и подлежит журналированию.

Управление изменениями

Изменения в промышленных системах вносятся через процедуру управления изменениями с указанием причины, плана работ и плана отката. Плановые окна согласуются с владельцами систем. Экстренные изменения оформляются постфактум в течение одного рабочего дня.

Изменения классифицируются как стандартные, обычные и экстренные. Стандартные изменения выполняются по заранее согласованным процедурам без дополнительного согласования; обычные требуют согласования владельцем системы.

После внесения изменения проводится проверка работоспособности по согласованному перечню проверок. При отрицательном результате выполняется откат в соответствии с планом, а причины анализируются на ближайшем совещании.

Мониторинг и журналирование

События информационной безопасности фиксируются в централизованной системе журналирования. Срок хранения журналов определяется внутренними требованиями. Доступ к журналам предоставляется ограниченному кругу лиц.

Перечень событий, подлежащих регистрации, включает попытки аутентификации, изменения прав доступа, действия привилегированных учётных записей и изменения конфигурации средств защиты.

Целостность журналов обеспечивается ограничением прав на изменение и регулярной выгрузкой в отдельное хранилище. Анализ журналов выполняется по установленному регламенту и по запросу в рамках расследований.

Реагирование на инциденты

Инцидент регистрируется по факту обнаружения и классифицируется по степени критичности. Дежурный инженер принимает первичные меры и при необходимости эскалирует обращение. Разбор по завершении инцидента проводится без поиска виновных.

Для каждого класса инцидентов определены целевые сроки реакции и восстановления. Ход работы фиксируется в системе учёта обращений; переписка по инциденту ведётся в одной ветке.

По итогам инцидентов высокой критичности готовится отчёт, содержащий хронологию, влияние, первопричину и перечень мер. Отчёт направляется владельцам затронутых систем и хранится в общем каталоге.

Работа с подрядчиками и доступ извне

Удалённый доступ подрядчиков предоставляется на ограниченный срок и только к согласованным ресурсам. Действия подрядчиков подлежат журналированию. По завершении работ доступ отзывается в течение одного рабочего дня.

До предоставления доступа с подрядной организацией заключается соглашение о конфиденциальности. Перечень предоставленных доступов ведётся службой информационной безопасности.

Работы, выполняемые подрядчиком в промышленной среде, проводятся в согласованные окна и, при высокой критичности системы, в присутствии ответственного работника заказчика.